

Falconi Incident Report Form

Executive Summary

On July 9th, 2025, Falconi Sports Agent Toad S. Worth reported suspicious system behavior after entering his credentials into what appeared to be a legitimate company login portal. The page was later confirmed to be part of a phishing scam. Shortly after entering his credentials, Toad noticed unusual system behavior and alerted the Falconi Cybersecurity Team.

The team's investigation revealed that unauthorized access had occurred on host 10.129.43.29, including the creation of a local user account named "hacker" with administrative privileges. TCP sessions were also detected between the compromised host and 10.129.43.4 over port 4444, commonly associated with reverse shell and backdoor activity. Privilege escalation commands were executed shortly after login, confirming active attacker control.

The Falconi Cybersecurity Team acted swiftly to isolate the compromised endpoint, remove the unauthorized user, and block port 4444 at the firewall to prevent future abuse. Falconi's SOC team successfully contained the threat, eliminated the attacker's persistence mechanisms, and restored the affected system to a secure operational state. No core business systems were compromised, and no sensitive client data was accessed. This incident reinforces the importance of phishing awareness, access control, and rapid employee reporting in maintaining Falconi's cybersecurity resilience.

Incident Details

- Date/Time Detected: July 9, 2025 1:30 PM EST
- Reported By: Toad S Worth, Falconi Sport's Agent
- Documented By: Daisy Maroni, Lead SOC Analyst
- Detection Method: Employee Alert
- System(s) Affected: No major systems, isolated employee account
- Incident Type: Unauthorized Access, Privilege Escalation, C2 communication
- Incident Severity Level: 2
- Incident Status: Resolved



Description of the Incident

The attack originated through a phishing email received by Toad S. Worth, a sports agent at Falconi. The email mimicked Falconi's internal portal and prompted him to input his login credentials. After submitting his username and password, Toad observed unusual behavior on his device, such as unexpected command windows and lag. Recognizing the irregular activity, he immediately contacted the Falconi Cybersecurity Team, which initiated the investigation and response.

The following sequence of attacker activities was reconstructed from network and host logs:

1. Between 12:58:53-12:59:45 EST on July 9, 2025, sustained TCP communication was observed between 10.129.43.29 (source) and 10.129.43.4 (destination) over port 4444, a commonly known backdoor/control port.
2. The connection began with a SYN packet and quickly transitioned into persistent PSH, ACK packets, behavior that aligns with reverse shell communication. The compressed one-minute duration of the session, paired with consistent packet exchange, strongly suggests the use of an automated post-exploitation tool or shell. This timeline aligns with other indicators such as unauthorized account creation and elevated privileges, confirming this phase as active attacker control.
3. A packet capture revealed an active session during which the attacker:
4. The attacker identified current user\ via the 'whoami' command.
5. Ran ipconfig to map internal IPs, gateways, and DNS servers—key information for further lateral movement.
6. Changed the working directory to the root of the C: drive to explore the file system.
7. Used 'dir' to list all files and directories, likely scanning for sensitive documents or config files.
8. Created a persistent backdoor user named hacker and escalated it to the Administrators group.
9. Maintained access by establishing ongoing TCP connections using port 4444—potentially exfiltrating data or awaiting additional payloads.



The system was isolated before broader impact occurred. The following actions align with the Reconnaissance, Exploitation, Privilege Escalation, and Command and Control phases of the cyber kill chain:

Indicator of Compromise

- Unusual TCP traffic between 10.129.43.29 and 10.129.43.4 over port 4444, a known vector for malware and remote shell activity.
- Creation of a new local user account named "hacker" with administrative privileges.
- Evidence of lateral movement attempts and potential persistence via manual user creation.
- Unusual PowerShell or command-line behavior

Impact Assessment

Data Compromised:

- Local user credentials, system configuration files, and potentially sensitive user-generated data.
- No evidence of data exfiltration was detected, but activity strongly indicates data enumeration and targeting.

Systems Outage/Downtime:

- No full outages were observed. Host 10.129.43.29 remained online until isolated by IT security.

Business Operations Affected:

- While no core systems were compromised, the incident jeopardized trust boundaries, presenting a medium-risk exposure to sensitive local data and credentials.

Users Impacted:

- Isolated to the local user(s) of host 10.129.43.29, though further log analysis is ongoing to determine the access of the "hacker" account attempted or achieved.
- Possible credential reuse concerns if passwords were shared across systems.

Mitigation & Containment Steps



- 1) The team isolated the compromised computer from the network
 - a. Removed 10.129.43.29 from the network to prevent lateral movement from the attacker and to stop further damage
 - b. Scanned the host and removed any malware and malicious payloads that were downloaded by the attack.
- 2) IT removed “hacker” user from the system
 - a. Documented actions that *hacker* took on the network to check what malicious activity occurred
 - b. Deleted *hacker* to stop attackers from having access to a privileged account
- 3) Updated firewall to block traffic over port 4444
 - a. Blocked inbound and outbound traffic over TCP port 4444 to stop it from being used in any future attacks

Lessons Learned & Protection

Access Controls & Monitoring:

- Monitor Admin Changes, review access control policies.
- Disable creation of local accounts on standard employee machines unless explicitly approved.
- Limit execution of PowerShell scripts and command-line tools to authorized personnel.

Network Security:

- Block Risky Port, monitor unusual traffic, isolate critical systems.

Employee Awareness:

Improve employee training on phishing and suspicious emails

Supporting Attachments



3	2025-07-09 12:58:53.818650	10.129.43.29	10.129.43.4	TCP	66	50612 → 4444	[SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
4	2025-07-09 12:58:53.818795	10.129.43.4	10.129.43.29	TCP	66	4444 → 50612	[SYN, ACK] Seq=0 Ack=1 Win=64248 Len=0 MSS=1460 SACK_PERM WS=128
5	2025-07-09 12:58:53.818850	10.129.43.29	10.129.43.4	TCP	66	50612 → 4444	[ACK] Seq=1 Ack=1 Win=2182272 Len=0
6	2025-07-09 12:58:53.881332	10.129.43.29	10.129.43.4	TCP	175	50612 → 4444	[PSH, ACK] Seq=1 Ack=1 Win=2182272 Len=121
7	2025-07-09 12:58:53.881278	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=1 Ack=122 Win=64128 Len=0
8	2025-07-09 12:59:04.486921	10.129.43.4	10.129.43.29	TCP	61	4444 → 50612	[PSH, ACK] Seq=1 Ack=122 Win=64128 Len=7
9	2025-07-09 12:59:04.555521	10.129.43.29	10.129.43.4	TCP	66	50612 → 4444	[ACK] Seq=122 Ack=8 Win=2182272 Len=0
10	2025-07-09 12:59:04.555556	10.129.43.29	10.129.43.4	TCP	118	50612 → 4444	[PSH, ACK] Seq=122 Ack=8 Win=2182272 Len=56
11	2025-07-09 12:59:04.555570	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=8 Ack=178 Win=64128 Len=0
12	2025-07-09 12:59:09.013100	10.129.43.4	10.129.43.29	TCP	63	4444 → 50612	[PSH, ACK] Seq=8 Ack=178 Win=64128 Len=9
13	2025-07-09 12:59:09.021950	10.129.43.29	10.129.43.4	TCP	64	50612 → 4444	[PSH, ACK] Seq=178 Ack=17 Win=2182272 Len=10
14	2025-07-09 12:59:09.021975	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=188 Win=64128 Len=0
15	2025-07-09 12:59:09.072232	10.129.43.29	10.129.43.4	TCP	254	50612 → 4444	[PSH, ACK] Seq=188 Ack=17 Win=2182272 Len=200
16	2025-07-09 12:59:09.072268	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=388 Win=64128 Len=0
17	2025-07-09 12:59:09.072421	10.129.43.29	10.129.43.4	TCP	841	50612 → 4444	[PSH, ACK] Seq=388 Ack=17 Win=2182272 Len=787
18	2025-07-09 12:59:09.072427	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=1175 Win=64128 Len=0
19	2025-07-09 12:59:15.395340	10.129.43.4	10.129.43.29	TCP	61	4444 → 50612	[PSH, ACK] Seq=17 Ack=1175 Win=64128 Len=7
20	2025-07-09 12:59:15.436636	10.129.43.29	10.129.43.4	TCP	68	50612 → 4444	[PSH, ACK] Seq=1175 Ack=24 Win=2182272 Len=14
21	2025-07-09 12:59:15.436689	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=24 Ack=1189 Win=64128 Len=0
22	2025-07-09 12:59:16.393040	10.129.43.4	10.129.43.29	TCP	58	4444 → 50612	[PSH, ACK] Seq=24 Ack=1189 Win=64128 Len=4
23	2025-07-09 12:59:16.456086	10.129.43.29	10.129.43.4	TCP	66	50612 → 4444	[ACK] Seq=1189 Ack=28 Win=2182272 Len=0
24	2025-07-09 12:59:16.456923	10.129.43.4	10.129.43.29	TCP	255	50612 → 4444	[PSH, ACK] Seq=1189 Ack=28 Win=2182272 Len=201
25	2025-07-09 12:59:16.456938	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=28 Ack=1390 Win=64128 Len=0
26	2025-07-09 12:59:16.457083	10.129.43.29	10.129.43.4	TCP	314	50612 → 4444	[PSH, ACK] Seq=1390 Ack=28 Win=2182272 Len=260
27	2025-07-09 12:59:16.457088	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=28 Ack=1650 Win=64128 Len=0
28	2025-07-09 12:59:35.514234	10.129.43.29	10.129.43.4	TCP	81	4444 → 50612	[PSH, ACK] Seq=28 Ack=1650 Win=64128 Len=31
29	2025-07-09 12:59:35.531329	10.129.43.4	10.129.43.29	TCP	86	50612 → 4444	[PSH, ACK] Seq=1650 Ack=59 Win=2182272 Len=32
30	2025-07-09 12:59:35.531364	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=59 Ack=1682 Win=64128 Len=0
31	2025-07-09 12:59:35.593896	10.129.43.29	10.129.43.4	TCP	99	50612 → 4444	[PSH, ACK] Seq=1682 Ack=59 Win=2182272 Len=45
32	2025-07-09 12:59:35.593932	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=59 Ack=1727 Win=64128 Len=0
38	2025-07-09 12:59:45.056004	10.129.43.4	10.129.43.29	TCP	96	4444 → 50612	[PSH, ACK] Seq=59 Ack=1727 Win=64128 Len=42
39	2025-07-09 12:59:45.057467	10.129.43.29	10.129.43.4	TCP	97	50612 → 4444	[PSH, ACK] Seq=1727 Ack=101 Win=2182272 Len=43
40	2025-07-09 12:59:45.057507	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=101 Ack=1770 Win=64128 Len=0
41	2025-07-09 12:59:45.119621	10.129.43.29	10.129.43.4	TCP	96	50612 → 4444	[PSH, ACK] Seq=1770 Ack=101 Win=2182272 Len=45
42	2025-07-09 12:59:45.119714	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=101 Ack=1815 Win=64128 Len=0

Figure 1

Packet capture of Toad's communications shows an unusual TCP connection over port 4444, which is a port we do not use.

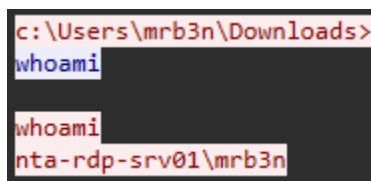


Figure 2

Once the attacker gains access to the employee's account, they use the 'whoami' command to see what account they gained access to. Based on this information, they can determine what type of account they gained access to and the permissions associated with that account, then take different actions based on that information.

```

c:\Users\mrb3n\Downloads>
ipconfig

ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::f8a1:e285:126d:3b73
    Temporary IPv6 Address. . . . . : dead:beef::70c2:7f40:2ff2:dffb
    Link-local IPv6 Address . . . . . : fe80::f8a1:e285:126d:3b73%4
    IPv4 Address. . . . . : 10.129.43.29
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:feb9:4ddf%4
                                10.129.0.1

Tunnel adapter isatap..htb:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : .htb

Tunnel adapter Teredo Tunneling Pseudo-Interface:

    Connection-specific DNS Suffix  . : 
    IPv6 Address. . . . . : 2001:0:2851:782c:28d9:1692:e895:c3a3
    Link-local IPv6 Address . . . . . : fe80::28d9:1692:e895:c3a3%2
    Default Gateway . . . . . :

```

Figure 3

Afterwards, the attacker used ipconfig for reconnaissance. This command helps them understand the network, the IP of the compromised account, the DNS server, type of subnet, and default gateway which can lead to routers or firewalls.

```
c:\Users\mrb3n\Downloads>  
cd c:\<br><br>cd c:\<br><br>c:\><br>dir<br><br>dir<br>Volume in drive C has no label.<br>Volume Serial Number is E8C0-6EAE<br><br>Directory of c:\<br><br>07/16/2016  04:47 AM  <DIR>          PerfLogs<br>05/10/2021  01:08 PM  <DIR>          Program Files<br>05/10/2021  01:08 PM  <DIR>          Program Files (x86)<br>05/10/2021  07:34 PM  <DIR>          Users<br>05/10/2021  12:46 PM  <DIR>          Windows<br>                0 File(s)                0 bytes<br><br>                5 Dir(s)  21,421,400,064 bytes free
```

Figure 4

The next thing the attacker did was change the working directory to the root of C drive. This will let the attacker gain a better understanding of all of the files of the system and explore where they want to go next.

That is why they used 'dir' to print out all the current files and folders in the directory. Here, they can choose what they want to target and start looking for sensitive information.

```
c:\>  
net user hacker Passw0rd1 /add  
  
net user hacker Passw0rd1 /add  
The command completed successfully.
```

Figure 5

The attacker created a persistent backdoor by adding a new user account with admin privileges.

```
c:\>  
net localgroup administrators hacker /add  
  
net localgroup administrators hacker /add  
The command completed successfully.  
  
c:\>
```

Figure 6

When continuing to examine the TCP connection, we can see that there was a successful privilege escalation of the *hacker* account into the administrator's group, gaining full control.